

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain J – Physical & Environmental Security

Table of Contents

Domain J - Physical & Environmental Security	4
J1. Physical Access Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (J1) [Informative]	16
MCP-Native Protocol Specification (J1) [Normative]	18
J2. Video Analytics Agent	19
Agent Blueprint [Informative]	19
Technical Implementation Details (J2) [Informative]	29
MCP-Native Protocol Specification (J2) [Normative]	31
J3. Facilities Security Agent	32
Agent Blueprint [Informative]	32
Technical Implementation Details (J3) [Informative]	44
MCP-Native Protocol Specification (J3) [Normative]	46
J4. OT Monitoring Agent	47
Agent Blueprint [Informative]	47
Technical Implementation Details (J4) [Informative]	58
MCP-Native Protocol Specification (J4) [Normative]	61
J5. Environmental Monitor Agent	61
Agent Blueprint [Informative]	61
Technical Implementation Details (J5) [Informative]	73
MCP-Native Protocol Specification (J5) [Normative]	75

Domain J - Physical & Environmental Security

J1. Physical Access Agent

Agent Blueprint [Informative]

Purpose: Control and monitor badge/biometric access to facilities and restricted areas; enforce policy (e.g., anti-passback, two-person rule); coordinate facility lockdown under incident missions.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Access Requests** (REST/Ticket/IGA): subject identity (employee_id, badge_id), requested areas/doors, validity window, approvals, risk_flags (e.g., crown_jewel_zone), SoD conflicts, justification.
- **Door/Reader Events** (PACS Syslog/CEF/REST): badge_id, reader_id, event (granted/denied), reason (ANTIPASSBACK, BIOMETRIC_MISMATCH), door state, optional biometric match scores.

Model training / knowledge (what the LLM relies on):

- Style/policy prompt pack for physical security norms: NIST 800-53 PE family, site rules (two-person rule, anti-passback), emergency access playbooks.
- RAG sources: PACS zone topology, anti-passback state cache, badge/role mappings, approved exception catalog; do not train on raw access logs (PII)—use evidence_refs.
- Guardrails: allow/deny lists for callable endpoints (PACS write APIs, incident APIs); immutable read-only scope on historical logs; constrained actions when lockdown active.

Decisions it makes (deterministic + model-assisted):

- **Authorize/Deny/Require-Second-Person** for access requests using SoD/zone risk, anti-passback state, biometric signal, approvals present, and mission context.
- **Live event enforcement:** auto-deny on anti-passback violations; trigger local alarm on tailgating; escalate to lockdown if incident policy matched.
- **Lockdown orchestration:** decide site/zone scope from mission_id, issue LockdownInitiated with whitelists (first responders) and egress rules.

- **Classification:** label outputs C3 when PII present; elevate to legal_hold when law-enforcement engaged.

Routing / where outputs go:

- **AccessDecision (grant/deny/require_second_person)** → PACS/Badge system (REST/gRPC).
- **Kafka/AMQP events:** PhysicalAccessDecision, LockdownInitiated to analytics/SIEM/SOAR.
- **Incident tie-in:** attach/join mission in incident mgmt (REST), update case timeline.

Automation scope vs. manual/HITL:

- Fully automated: anti-passback checks; time-window validation; approvals presence check; standard grants/denials outside CrownJewels.
- **HITL required:** overrides involving CrownJewels zones; biometric mismatches above threshold; VIP/visitor exceptions; any denial under declared medical emergency.
- Manual outside agent: establishing physical policy baselines and zoning; facilities maintenance modes; post-incident legal coordination.

Security Domain: Physical & Environmental Security

Inputs (native protocols consumed) [Informative]

1. **Access Requests (REST/Ticket/IGA)** — evaluate and authorize time-bounded or permanent area/door access.
2. **Door/Reader Events (PACS Syslog/CEF/REST)** — real-time granted/denied, forced-open, tailgating signals.

Example: Consumed Protocol — Access Requests (REST/Ticket/IGA) [Informative]

Native payload

```
{
  "request_id": "PAR-2025-0815-0142",
  "subject": { "employee_id": "E102993", "name": "April Ng", "badge_id": "B-77821" },
  "areas": [ { "site": "HQ-NYC", "zone": "DataCenter-1", "doors": ["DC1-North", "DC1-South"] } ],
```

```

"access_type": "time-bounded",
"valid_from": "2025-08-18T13:00:00Z",
"valid_to": "2025-08-18T17:00:00Z",
"justification": "Emergency hardware swap",
"approvals": ["payments.eng.manager", "facilities.supervisor"],
"risk_flags": ["crown_jewel_zone"],
"sod_conflicts": [],
"submitted_ts": "2025-08-15T12:40:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-incident-77aa-cc11-lockdown-nyc",
    "thread_id": "uuid-par-PAR-2025-0815-0142",
    "task_id": "uuid-authz-dc1-doors-001",
    "role": "PhysicalAccessAgent",
    "intent": "authorize",
    "policy_refs": ["NIST800-53 PE-2", "PE-3", "PE-8"],
    "constraints": ["two_person_rule", "anti_passback", "first_responder_whitelist"],
    "decision_basis": {
      "evidence_refs": ["uri://iga/requests/PAR-2025-0815-0142"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/physsec/policies/dc1-critical-zones"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/physsec/physical-access-agent",

```

```

    "signing_kid": "kid-iga-req-01",
    "attestation_ref": "uri://slsa/attestations/phys-access@sha256:req01"
  },
  "classification": "C3",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Door/Reader Events (PACS Syslog/CEF/REST)
 [Informative]

Native payload (CEF-style) + normalized JSON

CEF:0|PACS|Reader|5.4|ACCESS_DENIED|Denied - AntiPassback Violation|8|
 rt=2025-08-15T13:05:21Z src=HQ-NYC deviceFacility=HQ-NYC cs1Label=badgeld
 cs1=B-77821

cs2Label=readerId cs2=DC1-North cs3Label=reason cs3=ANTIPASSBACK

```

{
  "timestamp": "2025-08-15T13:05:21Z",
  "facility": "HQ-NYC",
  "reader_id": "DC1-North",
  "badge_id": "B-77821",
  "event": "ACCESS_DENIED",
  "reason": "ANTIPASSBACK",
  "biometric": {"used": false, "match_score": null},
  "door_state": "closed"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {

```

```

"mcp_version": "0.9",
"mission_id": "uuid-incident-77aa-cc11-lockdown-nyc",
"thread_id": "uuid-reader-DC1-North-2025-08-15T13:05:21Z",
"task_id": "uuid-monitor-dc1-north-evt-001",
"role": "PhysicalAccessAgent",
"intent": "monitor",
"policy_refs": ["NIST800-53 PE-3", "PE-6", "IR-4"],
"constraints": ["anti_passback", "lockdown:enabled"],
"decision_basis": {
  "evidence_refs": ["uri://pacs/cef/HQ-NYC/DC1-North/2025-08-15T13:05:21Z"],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/physsec/anomalies/antipassback"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/physsec/physical-access-agent",
  "signing_kid": "kid-pacs-evt-02",
  "attestation_ref": "uri://slsa/attestations/phys-access@sha256:pacs02"
},
"classification": "C3",
"legal_hold": true
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **AccessGrant / AccessDenial** → PACS/Badge system (REST/gRPC).
- **Events** → Kafka/AMQP: PhysicalAccessDecision, LockdownInitiated.

- **Incident tie-ins** → REST to incident management to join/annotate active mission.

MCP context (required) [Informative]

mission_id (link to ongoing incident/lockdown campaign when applicable);
role="PhysicalAccessAgent"; intent in {"authorize","monitor"}; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (e.g., PE-2, PE-3, PE-6, PE-8); constraints (e.g., "two_person_rule", "anti_passback", "first_responder_whitelist", "lockdown:enabled"); classification (usually C3); decision_basis; legal_hold

Enforcement note [Informative]

PEPs at PACS and facility controllers must verify **provenance.attestation** and, during lockdown, enforce **first_responder_whitelist** and anti-tailgating rules before honoring AccessGrant.

NIST SP 800-160v2 linkage [Informative]

Implement/Maintain — resilient physical access control integrated with cyber incident response missions.

Automation feasibility [Informative]

High: policy checks and monitoring are automatable; emergency overrides and critical-zone denials require HITL.

Output Contracts (merged) [Informative]

OC-1: PhysicalAccessDecision (Grant/Deny/RequireSecondPerson) [Informative]

- **Producer(s):** J1
- **Topic/Path:** POST /pacs/access_decisions or gRPC pacs.Access/Decision
- **Schema/Format:** AccessDecision@1.0 (decision, subject, zone, door, reason, constraints_applied, evidence_refs)
- **Classification:** C3
- **Delivery:** exactly-once per request_id OR per reader_event_id
- **Ordering:** per-subject_id

- **Idempotency-Key:** sha256(subject_id, door_id, decision_window_start, decision_window_end)
- **Ack/Nack:** 200/201 or gRPC OK; NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=5 s; exp-backoff<=5x; on persistent NACK → HITL
- **Side-Effects:** PACS state update (anti-passback registers), audit append, notify SIEM
- **HITL Token:** required for CrownJewels zones, biometric mismatch, VIP/visitor exception
- **Observability:** trace_id, mission_id, policy_refs, constraints_applied, evidence_refs, decision_basis.confidence, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AccessDecision@1.0 | json_schema_uri=uri://schema/access-decision-1.0.json | sha256= | producers=J1 | consumers=PACS-01, SIEM-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: LockdownInitiated (with Whitelists and Egress Rules) [Informative]

- **Producer(s):** J1
- **Topic/Path:** Kafka topic sec.phys.lockdown; REST POST /pacs/lockdown
- **Schema/Format:** LockdownInitiated@1.0 (mission_id, scope={site|zone|doors}, whitelist, egress_policy, reason, ttl)
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per-site
- **Idempotency-Key:** sha256(mission_id, scope_hash, ttl_floor_60s)
- **Ack/Nack:** PACS ACK<=10 s; broadcast acks to incident system

- **Timeouts/Retry:** exp-backoff<=5x; on failure, fall back to local controllers and alert HITL
- **Side-Effects:** synchronize with incident mgmt; update building signage/alarms
- **HITL Token:** required to expand scope beyond predefined zones
- **Observability:** trace_id, mission_id, scope, enforcement_status, classification_label, provenance.attestation
- **Retention/TTL:** mission lifetime + 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When mission intent includes lockdown or when incident policy triggers physical containment

schema_id=LockdownInitiated@1.0 | json_schema_uri=uri://schema/lockdown-initiated-1.0.json | sha256= | producers=J1 | consumers=PACS-01, SOAR-01, Incident-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: AccessDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** J1, Facilities-Portal-01, HR/Legal portals
- **Topic/Path:** sec.phys.contestation
- **Schema/Format:** AccessDispute@1.0 (decision_id, subject_id, reason_codes, decision_rationale_url)
- **Classification:** C3+
- **Delivery/Ordering:** at-least-once; per-decision_id
- **Idempotency-Key:** sha256(decision_id, dispute_id)
- **Ack/Nack:** case_id in <=30 s else retry/backoff
- **Side-Effects:** pause auto-denials for subject_id if severity=high; HITL required
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled for physical access

schema_id=AccessDispute@1.0 | json_schema_uri=uri://schema/access-dispute-1.0.json | producers=J1, Facilities-Portal-01 | consumers=Legal-01, Compliance-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

OC-4: IRPhysicalAccessEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** J1
- **Topic/Path:** sec.phys.incident
- **Schema/Format:** IRPhysicalAccessEvent@1.0 (incident_id, decision_id, artifacts)
- **Classification:** C2/C3
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, decision_id)
- **Ack/Nack:** SIEM/CaseID assigned in <=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach door video pointer if available
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** per IR policy (>=1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPhysicalAccessEvent@1.0 | json_schema_uri=uri://schema/ir-physical-access-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: AccessChangeImpactReport (Zoning/Policy Drift) [Informative, optional]

- **Producer(s):** J1 (pre-deploy of zone/policy changes)
- **Topic/Path:** sec.phys.change_impact
- **Schema/Format:** AccessChangeImpactReport@1.0 (affected_zones, predicted_denial_rate_delta, evac_egress_impact)
- **Classification:** C1

- **Delivery/Ordering:** at-least-once; per-change_request_id
- **Idempotency-Key:** sha256(change_request_id, version)
- **Ack/Nack:** comment/reference attached to change; retry/backoff
- **Side-Effects:** gate production rollout per thresholds
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring is enabled for PACS/policy rollout

schema_id=AccessChangeImpactReport@1.0 | json_schema_uri=uri://schema/access-change-impact-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Facilities/Guard portals; J1 (aggregation)
- **Topic/Path:** sec.phys.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (artifact_id, review_id, labels={helpful|neutral|harmful})
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, artifact_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** add to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, artifact_id, labels
- **Retention/TTL:** 1 year (or per HR/Legal)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-

State machine (concise) [Informative]

states = { idle, **authorizing_request**, **monitoring_events**, granting_access, denying_access, enforcing_lockdown, contestation_workflow, failed, closed }

transition(idle -> authorizing_request) when Access Request received

transition(idle -> monitoring_events) when reader stream connected

transition(authorizing_request -> granting_access) when policy checks pass and constraints satisfied

transition(authorizing_request -> denying_access) when violation detected OR approvals missing

transition(monitoring_events -> denying_access) on antipassback/biometric violation

transition(* -> enforcing_lockdown) when mission intent=lockdown OR lockdown policy triggers

transition(* -> contestation_workflow) when AccessDispute opened OR stakeholder_disagreement_score >= 0.5

timeout(granting_access, 5 s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(subject_id, door_id, decision_window)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PhysicalAccessDecision	Required	Always	Core facility access control
OC-2 LockdownInitiated	Conditionally Required	Mission lockdown or policy trigger	Rapid containment & safety
OC-3 AccessDispute	Optional	Contestability enabled	Governance & due process
OC-4 IRPhysicalAccessEvent	Optional	IR/SIEM integration present	Incident response integration

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-5 AccessChangeImpactReport	Conditionally Required	Change impact scoring enabled for PACS/policy rollout	Risk-aware change management
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** NIST 800-53 PE-2 (Physical Access Authorizations), PE-3 (Monitoring), PE-6 (Access Control), PE-8 (Visitor Access Records), IR-4 (Incident Handling).
- **HITL required:** CrownJewels zones; biometric mismatch above threshold; VIP/visitor exceptions; scope expansion during lockdown.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; repeated denials at same reader (tailgating cluster).
- **Manual outside agent:** policy baseline design; legal coordination.

SLOs and KPIs [Informative]

- AccessDecisionLatency_p95 <= 5 s
- FalseAcceptRate_30d <= 0.5 percent
- FalseRejectRate_30d <= 1.0 percent
- LockdownAck_p95 <= 10 s
- AppealResolution_p95 <= 5 business days

Outputs index [Informative]

[OC-1 PhysicalAccessDecision], [OC-2 LockdownInitiated], [OC-3 AccessDispute], [OC-4 IRPhysicalAccessEvent], [OC-5 AccessChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (J1) [Informative]

Model and training profile [Informative]

model_id=phys-access-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=physsec-policy-v1 (two-person rule, anti-passback, emergency playbooks)
RAG: sources={zone topology, anti-passback registry, badge-role catalog, mission KB};
max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval on rule adherence + hallucination bounds
guardrails: PACS write endpoints allowlisted; deny non-PACS writes; scoped tokens;
mission-scoped actions only

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (decisions, events, lockdown changes),
ttl=365d
semantic_memory: namespaces=["zones","badges","exceptions","missions"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced anti-passback ledger + decision journal; snapshot
per zone/hour
consistency: exactly-once for AccessDecision; at-least-once for LockdownInitiated
idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{access_risk_score} = 0.35\text{zone_risk} + 0.25\text{biometric_risk} + 0.20\text{history_anomaly} + 0.10\text{approval_gap} + 0.10\text{mission_sensitivity}$
 $\text{grant_if} = (\text{access_risk_score} < \text{theta_grant}) \text{ AND constraints_satisfied}$
 $\text{require_second_person_if} = (\text{zone_requires_two_person} \text{ OR } \text{access_risk_score} \text{ in } [\text{theta_grant}, \text{theta_deny}])$
 $\text{deny_if} = (\text{anti_passback_violation} \text{ OR } \text{access_risk_score} \geq \text{theta_deny} \text{ OR } \text{approvals_missing_critical})$
 $\text{lockdown_scope} = f(\text{mission_id}, \text{incident_indicators}, \text{adjacency_graph})$

Model Risk Management [Informative]

continuous_validation: daily (goldens/adversarial/jailbreak); eval_pass_rate ≥ 99.5 percent $\rightarrow$ else auto_HITL

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

red_team_cycle: monthly (tailgating, badge clone, reader spoof)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; constraints_applied; hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL (stable fields); retention per classification/legal_hold

Incident Response Integration [Informative]

emit IRPhysicalAccessEvent (OC-4) to sec.phys.incident; attach reader/door and camera pointers; join incident via mission_id

Change Impact Assessment [Informative]

compute change_impact_score for zoning/policy updates; emit AccessChangeImpactReport (OC-5); gate rollouts

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6) from guard/facilities reviews; governance-reviewed updates to prompts/rules (no auto-training on PII logs)

Data Sovereignty and Legal Hold [Informative]

PII in access logs → default C3; region-bound processing per data_locality_policy; legal_hold=true overrides TTL, blocks purge

Interfaces (links only) [Informative]

Consumes: Access Requests (REST/Ticket/IGA); Door/Reader Events (PACS Syslog/CEF/REST)
Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on provenance verification failure; fail-safe policy (fail-secure in CrownJewels; fail-open on emergency egress); blast-radius caps on bulk denials

Testing and validation [Informative]

contract tests (Schema Capsules); replay historical events; red-team drills (tailgating/clone); drift checks and rollback

Deployment and lifecycle [Informative]

scaling/HPA by reader QPS; canary LockdownInitiated; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (PE, IR families); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE D3FEND (physical entry/egress patterns); SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (J1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Access Requests (REST/Ticket/IGA); Door/Reader Events (PACS Syslog/CEF/REST)
- **Native Protocol(s) Produced:** AccessGrant/AccessDenial (REST/gRPC); PhysicalAccessDecision, LockdownInitiated (Kafka/AMQP); incident join/update (REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="PhysicalAccessAgent"; intent in {"authorize","monitor"}; provenance.attestation (SPIFFE/SLSA KID)
 - **Optional:** policy_refs (PE-2, PE-3, PE-6, PE-8); constraints ("two_person_rule","anti_passback","first_responder_whitelist","lockdown:enabled"); classification; decision_basis; legal_hold
- **Enforcement Note:** PACS/PEPs MUST verify provenance and active lockdown constraints before honoring AccessGrant.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

J2. Video Analytics Agent

Agent Blueprint [Informative]

Purpose: Analyze CCTV streams for security-relevant anomalies (e.g., tailgating, intrusion to restricted zones, loitering near entrances) and emit **PhysicalAnomalyAlert** events with immutable evidence packages suitable for law-enforcement handoff.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Video feeds** (RTSP/RTP via ONVIF/SDP): camera SDP, stream URI, frame rate, codec; zone mapping and camera calibration metadata.
- **Analytics models** (Model Registry via REST/Object Store; ONNX/TensorRT): model artifacts, version, thresholds, calibration profile and checksum.

Model training / knowledge (what the LLM relies on):

- Prompt pack for video security semantics (tailgating, restricted zones, loitering windows, business-hours rules).
- RAG sources: camera-to-zone topology, restricted-area polygons, mission playbooks; do not train on raw CCTV (PII). Use `evidence_refs` and derived features.
- Guardrails: `privacy_masking:true` enforced before analysis export; `no_biometric_id:true` (no face recognition or re-identification); tools limited to model fetch, object store write, event publish, incident REST.

Decisions it makes (deterministic + model-assisted):

- Detect and classify anomalies: Tailgating, ZoneIntrusion, Loitering, ForcedOpen, CameraTamper.
- Score events and decide **alert vs. suppress** using confidence, zone criticality, and temporal persistence.
- Package immutable evidence (clip, keyframes, detection JSON, hashes); decide **legal_hold** based on `mission_id` and policy.
- Join incident and route evidence when a relevant mission is active.

Routing / where outputs go:

- **PhysicalAnomalyAlert** → Kafka/AMQP to SIEM/SOAR and facilities dashboards.

- **EvidencePackage** → Object storage (S3/Blob) with content hashes and chain-of-custody record.
- **Incident tie-in** → REST to incident management to join mission and attach evidence references for law enforcement.

Automation scope vs. manual/HITL:

- Fully automated: ingestion, inference, anomaly scoring, alert emission, evidence packaging with cryptographic hashing.
- **HITL required:** release of footage to external parties; privacy-mask exceptions; alerts with low confidence in CrownJewels zones; disputes or appeals.
- Manual outside agent: camera maintenance and calibration; legal disclosure workflow; policy baseline of restricted zones.

Security Domain: Physical & Environmental Security

Inputs (native protocols consumed) [Informative]

1. **Video Feeds (RTSP/RTP over ONVIF/SDP)** — live streams from the VMS/PACS network.
2. **Analytics Models (Model Registry; ONNX/TensorRT)** — model artifacts and configs.

Example: Consumed Protocol — Video Feeds (RTSP/SDP) [Informative]

Native payload (SDP descriptor)

```
v=0
o=- 2890844526 2890842807 IN IP4 192.0.2.10
s=Camera HQ-NYC Lobby
t=0 0
m=video 0 RTP/AVP 96
c=IN IP4 0.0.0.0
a=rtpmap:96 H264/90000
a=control:trackID=1
a=framerate:30.000000
a=tool:ONVIF Media2
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-incident-nyc-dc1-2025-08-15",
    "thread_id": "uuid-rtsp-camera-HQ-NYC-Lobby",
    "task_id": "uuid-infer-clip-001",
    "role": "VideoAnalyticsAgent",
    "intent": "analyze",
    "policy_refs": ["NIST800-53 PE-3", "PE-6", "AU-9"],
    "constraints": ["privacy_masking:true", "no_biometric_id:true"],
    "decision_basis": {
      "evidence_refs": [
        "uri://rtsp/sdp/HQ-NYC/Lobby",
        "s3://evidence/cctv/HQ-NYC/Lobby/2025-08-15T13:05:21Z/clip.mp4",
        "s3://evidence/cctv/HQ-NYC/Lobby/2025-08-15T13:05:21Z/keyframe_00042.jpg",
        "sha256://f5b0...a91e"
      ],
      "confidence": 0.92,
      "explanation_ref": "uri://kb/video/anomaly-tailgating-v2"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/physenv/video-analytics-agent",
      "signing_kid": "kid-rtsp-01",
      "attestation_ref": "uri://slsa/attestations/video-analytics@sha256:rtsp01"
    },
    "classification": "C3",
  }
}
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    "legal_hold": true
  },
  "native_payload": "v=0\no=- 2890844526 2890842807 IN IP4 192.0.2.10\ns=Camera
HQ-NYC Lobby\nt=0 0\nm=video 0 RTP/AVP 96\nc=IN IP4 0.0.0.0\na=rtpmap:96
H264/900000\na=control:trackID=1\na=framerate:30.000000\na=tool:ONVIF Media2\n"
}

```

Example: Consumed Protocol — Analytics Models (Model Registry; ONNX/TensorRT) [Informative]

Native payload

```

{
  "model_id": "phys-anomaly-yolo-v2.1",
  "framework": "onnx",
  "version": "2.1.0",
  "inputs": [{"name": "images", "shape": "1x3x640x640"}],
  "labels": ["person", "vehicle", "bicycle", "hardhat", "restricted_zone"],
  "thresholds": {"confidence": 0.55, "nms_iou": 0.45},
  "artifact_uri": "s3://models/video/phys-anomaly-yolo-v2.1/model.onnx",
  "checksum_sha256": "9c4a2e...d1bf",
  "calibration_profile": "tensorRT_int8_calib_v5.json"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-incident-nyc-dc1-2025-08-15",
    "thread_id": "uuid-model-phys-anomaly-yolo-v2.1",
    "task_id": "uuid-infer-setup-002",
    "role": "VideoAnalyticsAgent",

```

```

"intent": "analyze",
"policy_refs": ["PE-6", "AU-12"],
"decision_basis": {
  "evidence_refs": [
    "s3://models/video/phys-anomaly-yolo-v2.1/model.onnx",
    "sha256://9c4a2e...d1bf",
    "uri://models/cards/phys-anomaly-yolo-v2.1"
  ],
  "confidence": 1.0,
  "explanation_ref": "uri://kb/video/model-governance#v2.1"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/physenv/video-analytics-agent",
  "signing_kid": "kid-model-02",
  "attestation_ref": "uri://slsa/attestations/video-analytics@sha256:model02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- Kafka/AMQP: **PhysicalAnomalyAlert** (includes clip/frame URIs, hashes).
- Object Storage: **EvidencePackage** (clip + keyframes + detection JSON + hashes).
- REST to Incident Mgmt: join/attach to incident missions with evidence refs.

MCP context (required) [Informative]

mission_id; role="VideoAnalyticsAgent"; intent="analyze"; provenance (SPIFFE ID, signing KID, attestation); decision_basis (evidence_refs, model_version, thresholds).

MCP context (optional) [Informative]

policy_refs (e.g., NIST 800-53 PE-3, PE-6, PE-8; AU-9); constraints (e.g., "privacy_masking:true", "no_biometric_id:true"); classification="C3"; legal_hold=true when escalated to LE.

Enforcement note [Informative]

Downstream PEPs must verify **classification_label**, **provenance.attestation**, and presence of **content hashes** before accepting evidence; UIs must honor **privacy_masking** and forbid biometric ID.

NIST SP 800-160v2 linkage [Informative]

Implement/Maintain — resilient physical monitoring integrated with incident response.

Automation feasibility [Informative]

High (ingest, inference, packaging, and event emission are automatable; LE disclosure requires HITL).

Output Contracts (merged) [Informative]

OC-1: PhysicalAnomalyAlert [Informative]

- **Producer(s):** J2
- **Topic/Path:** Kafka topic sec.video.anomaly or AMQP sec.video.anomaly
- **Schema/Format:** PhysicalAnomalyAlert@1.0 (anomaly_type, zone, camera_id, confidence, start_ts, end_ts, evidence_refs, hashes, policy_refs, constraints_applied)
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per-camera_id
- **Idempotency-Key:** sha256(camera_id, start_ts, anomaly_type)
- **Ack/Nack:** broker ACK; NACK on publish error; retry with exp-backoff<=5x
- **Timeouts/Retry:** first publish <= 5 s after end_ts
- **Side-Effects:** SIEM correlation ticket, dashboard annotation

- **HITL Token:** required when confidence < theta_low in CrownJewels zones
- **Observability:** trace_id, mission_id, model_version, thresholds, evidence_refs, hashes.sha256, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (or per policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PhysicalAnomalyAlert@1.0 | json_schema_uri=uri://schema/physical-anomaly-alert-1.0.json | sha256= | producers=J2 | consumers=SIEM-01, SOAR-01, Dash-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EvidencePackage [Informative]

- **Producer(s):** J2
- **Topic/Path:** s3://evidence/cctv/<site>/<camera>/<ts>/ (or Blob)
- **Schema/Format:** EvidencePackage@1.0 (clip_uri, keyframes[], detections.json, sha256 clip and files, chain_of_custody record, watermarking metadata)
- **Classification:** C3 (legal_hold=true when tied to incident)
- **Delivery:** exactly-once per anomaly_id
- **Ordering:** per-anomaly_id
- **Idempotency-Key:** sha256(anomaly_id)
- **Ack/Nack:** 201 Created for each object; NACK on 4xx/5xx
- **Timeouts/Retry:** package finalize <= 30 s; exp-backoff<=5x
- **Side-Effects:** append audit journal entry; update incident timeline if mission active
- **HITL Token:** required to export package to external sharing bucket
- **Observability:** trace_id, mission_id, model_version, thresholds, evidence_refs, hashes, classification_label, provenance.attestation
- **Retention/TTL:** 90 days default; override on legal_hold

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EvidencePackage@1.0 | json_schema_uri=uri://schema/evidence-package-1.0.json | sha256= | producers=J2 | consumers=LE-Portal-01, Incident-01, Archive-01 | accepts=1.0–1.x

Conformance: Normative.

OC-3: IRVideoEvidenceEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** J2
- **Topic/Path:** sec.video.incident (REST to Incident Mgmt: POST /incidents/{id}/evidence)
- **Schema/Format:** IRVideoEvidenceEvent@1.0 (incident_id, anomaly_id, evidence_refs, hashes, decision_rationale_url)
- **Classification:** C2/C3
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, anomaly_id)
- **Ack/Nack:** CaseID attach in <= 30 s; retry/backoff
- **Retention/TTL:** per IR policy (>= 1 year)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When IR/SIEM integration is present or mission is active

schema_id=IRVideoEvidenceEvent@1.0 | json_schema_uri=uri://schema/ir-video-evidence-1.0.json

Conformance: Normative when condition is met.

OC-4: ModelChangeImpactReport (Model Risk and Drift) [Informative, optional]

- **Producer(s):** J2 (on model or threshold change)
- **Topic/Path:** sec.video.change_impact
- **Schema/Format:** ModelChangeImpactReport@1.0 (model_id, old_vs_new_thresholds, predicted_alert_rate_delta, fp_fn_tradeoff)

- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-model_version
- **Idempotency-Key:** sha256(model_id, version)
- **Side-Effects:** gate promotion to production per thresholds

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When model governance with impact scoring is enabled

schema_id=ModelChangeImpactReport@1.0 | json_schema_uri=uri://schema/model-change-impact-1.0.json

Conformance: Normative when condition is met.

OC-5: FeedbackIngestionEvent (Operator Labels) [Informative, optional]

- **Producer(s):** Guard/Operator portals; J2 (aggregation)
- **Topic/Path:** sec.video.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, anomaly_id, label={helpful|neutral|harmful}, notes_url)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, anomaly_id)

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_stream, inferring, alerting, packaging_evidence, joining_incident, contestation_workflow, failed, closed }

transition(idle -> ingesting_stream) when RTSP session established

transition(ingesting_stream -> inferring) when model loaded and warm

transition(inferring -> alerting) when anomaly_score >= theta_alert for min_duration

transition(alerting -> packaging_evidence) when alert emitted
 transition(packaging_evidence -> joining_incident) when mission active
 transition(* -> contestation_workflow) when dispute opened or privacy exception requested
 timeout(packaging_evidence, 30 s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(camera_id, start_ts, anomaly_type)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PhysicalAnomalyAlert	Required	Always	Real-time security alerting
OC-2 EvidencePackage	Required	Always	Immutable evidence and chain-of-custody
OC-3 IRVideoEvidenceEvent	Conditionally Required	Mission active or IR/SIEM integration present	Incident response integration
OC-4 ModelChangeImpactReport	Conditionally Required	Model governance with impact scoring enabled	Safe model evolution
OC-5 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- policy_refs: NIST 800-53 PE-3, PE-6, PE-8; AU-9 (Protection of Audit Information).
- **HITL required:** release of footage externally; low-confidence alerts in CrownJewels; privacy-mask overrides; contested evidence.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; repeated CameraTamper at same camera.

SLOs and KPIs [Informative]

- AlertLatency_p95 <= 5 s from end_ts
- EvidencePackageFinalize_p95 <= 30 s
- FalseAlertRate_7d <= 2 percent
- MissedEventRate_7d <= 1 percent (measured on goldens)
- DriftDetect_MTTD <= 24 h

Outputs index [Informative]

[OC-1 PhysicalAnomalyAlert], [OC-2 EvidencePackage], [OC-3 IRVideoEvidenceEvent], [OC-4 ModelChangeImpactReport], [OC-5 FeedbackIngestionEvent]

Technical Implementation Details (J2) [Informative]

Model and training profile [Informative]

model_id=phys-anomaly-yolo-v2.1 (ONNX/TensorRT); temperature=0.0 (deterministic); max_tokens_out=0 for inference path
 thresholds: confidence=0.55; nms_iou=0.45; min_persistence=0.5 s (per anomaly)
 prompt_pack_id=video-anomaly-v1 (taxonomy, escalation, privacy)
 RAG: sources={camera topology, zone polygons, model cards}; max_docs=6; min_similarity=0.78
 fine_tuning/adapters: none initially; evaluation gates on FP/FN bounds; no training on PII frames stored beyond TTL
 guardrails: enforce privacy masking pre-export; disable biometric identification; restrict egress to evidence bucket and incident API

Memory and state [Informative]

working_memory.max_tokens=n/a (streaming); detection_cache.ttl=120 s
 episodic_memory: per mission_id journal of alerts/evidence_refs; ttl=365 d

semantic_memory: namespaces=["cameras","zones","models","missions"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced evidence ledger with hashes; snapshot per camera/hour
consistency: at-least-once for alerts; exactly-once for evidence packages
idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{anomaly_score} = 0.5\text{confidence} + 0.3\text{zone_risk} + 0.2*\text{temporal_persistence}$
alert_if = anomaly_score >= theta_alert
theta_alert default = 0.72; CrownJewels zones use theta_alert = 0.65 with HITL if
model_confidence < 0.6
tailgating_rule = persons_entering - persons_badged > 0 within window_w and
door_state=open
loitering_rule = person_present_duration >= t_loiter and zone in entrance_set
routing: alerts -> Kafka; evidence -> S3; if mission active -> incident attach

Model Risk Management [Informative]

continuous_validation: daily goldens/adversarial/jailbreak; eval_pass_rate >= 99.5
percent else auto_HITL
red_team_cycle: monthly probes (tailgating, camera occlusion, replay attacks)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h -> revert model_id; notify
owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: anomaly_type, why, where, when; model_version;
thresholds; evidence_refs; hashes
audit_log_format: JSONL; stable field order; include chain_of_custody events and
watermarking metadata
UI/API: surface classification_label, provenance.attestation, decision_rationale_url

Incident Response Integration [Informative]

emit IRVideoEvidenceEvent (OC-3) and attach to mission timeline; map severity by
zone_risk and anomaly_type

Change Impact Assessment [Informative]

emit ModelChangeImpactReport (OC-4) on threshold or model version change; gate
promotion on predicted_alert_rate_delta and fp_fn_tradeoff thresholds

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-5) from operator labels; governance-reviewed incorporation to prompt_pack or thresholds (no auto-training on incident footage)

Data Sovereignty and Legal Hold [Informative]

classification C3 by default; region-scoped buckets; legal_hold=true overrides TTL and blocks purge

Interfaces (links only) [Informative]

Consumes: Video Feeds (RTSP/ONVIF/SDP); Analytics Models (Registry/ONNX/TensorRT)

Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on provenance or hash mismatch; watermark evidence; privacy masks enforced; rate limits and cost caps per mission_id

Testing and validation [Informative]

contract tests for Schema Capsules; replay test harness; red-team drills; drift checks and automatic rollback

Deployment and lifecycle [Informative]

GPU autoscaling by stream QPS; canary model rollouts; SBOM and SLSA attestations; signed outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (PE, AU families); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; ONVIF; RTSP/SDP; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (J2) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Video Feeds (RTSP/RTP over ONVIF/SDP); Analytics Models (Model Registry; ONNX/TensorRT)

- **Native Protocol(s) Produced:** PhysicalAnomalyAlert (Kafka/AMQP); EvidencePackage (Object Storage); IRVideoEvidenceEvent (REST to Incident Mgmt, if enabled)
- **MCP Context Fields:**
 - **Required:** mission_id; role="VideoAnalyticsAgent"; intent="analyze"; provenance.attestation; decision_basis (evidence_refs, model_version, thresholds)
 - **Optional:** policy_refs (PE-3, PE-6, PE-8; AU-9); constraints ("privacy_masking:true", "no_biometric_id:true"); classification; legal_hold
- **Enforcement Note:** Consumers MUST verify hashes and provenance; UIs MUST apply privacy_masking and disallow biometric identification.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

J3. Facilities Security Agent

Agent Blueprint [Informative]

Purpose: Produce and maintain secure facility designs and retrofits (zoning, barriers, egress, surveillance, PACS topology), translating architectural assets and risk assessments into a governed **FacilitySecurityPlan**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Blueprints (BIM/CAD via IFC/REST):** floors/rooms, doors & egress, walls/barriers, restricted zones, route clearances, levels.
- **Physical Risk Assessments (Audit tool REST/CSV/JSON):** threats, likelihood/impact, CPTED findings, control gaps, recommendations.

Model training / knowledge (what the LLM relies on):

- Prompt pack for facility security design: zoning, PACS topology patterns, CPTED heuristics, camera coverage math, egress rules.
- RAG sources: BIM index, prior FacilitySecurityPlans, device catalog (cameras/readers/barriers), risk register; do **not** train on proprietary blueprints—use evidence_refs.
- Guardrails: read-only for CAD until plan draft; writes constrained to **FacilitySecurityPlan** endpoints, event bus topics, and CMMS/PACS/VMS change APIs; privacy_masking for any plan imagery containing camera FOVs if policy requires.

Decisions it makes (deterministic + model-assisted):

- Derive **zones** (public, controlled, restricted/CrownJewels) and **paths** (egress, visitor, logistics).
- Recommend and place **controls**: cameras (FOV, lens), readers, mantraps, barriers, alarms; compute coverage and blind spots.
- Validate **egress** and code-like constraints (min_clear_in, swing direction) per provided rules/constraints.
- Generate **FacilitySecurityPlan** with deltas (diff vs. previous) and produce **ConstructionWorkItem** tickets.
- Classify artifacts (C2 default) and set **legal_hold** when plans tie to active incidents/investigations.

Routing / where outputs go:

- **FacilitySecurityPlan** → Design registry/plan service (REST/JSON + attachments).
- **FacilityPlanUpdated** / **ConstructionWorkItem** → Kafka/AMQP to PACS/VMS/CMMS integrators.
- **Change tickets / work orders** → CMMS/PACS/VMS via REST (create/update).

Automation scope vs. manual/HITL:

- Fully automated: parse/normalize BIM, risk-to-control mapping, camera/readers initial placement, coverage math, draft plan generation, ticket pre-fill.
- **HITL required**: code interpretations with ambiguity; CrownJewels barrier/egress changes; budget/scope decisions; exceptions to constraints.

- Manual outside agent: local AHJ (Authority Having Jurisdiction) approvals; physical construction/installation; vendor selection.

Security Domain: Physical & Environmental Security

Inputs (native protocols consumed) [Informative]

1. **Blueprints (BIM/CAD via IFC/REST)** — floor plans, spaces, doors/egress, barriers, restricted zones.
2. **Physical Risk Assessments (Audit tool REST/CSV/JSON)** — threats/likelihood/impact, CPTED findings, gaps.

Example: Consumed Protocol — Blueprints (BIM/CAD via IFC/REST) [Informative]

Native payload

```
{
  "blueprint_id": "IFC-HQ-NYC-DC1-v7",
  "site": "HQ-NYC",
  "level": "B1",
  "spaces": [
    {"space_id": "DC1", "type": "DataCenter", "area_sqft": 4200, "egress_doors": ["D-N", "D-S"]},
    {"space_id": "ELEC-01", "type": "ElectricalRoom", "area_sqft": 320, "egress_doors": ["D-E1"]}
  ],
  "doors": [
    {"door_id": "D-N", "location": {"x": 18.3, "y": 42.7}, "swing": "out", "fire_rating_min": 90},
    {"door_id": "D-S", "location": {"x": 18.3, "y": 4.2}, "swing": "out", "fire_rating_min": 90},
    {"door_id": "D-E1", "location": {"x": 3.1, "y": 22.0}, "swing": "out", "fire_rating_min": 60}
  ],
  "barriers": [
    {"type": "CMU_wall", "thickness_in": 8, "height_ft": 12.0},
```

```

    {"type": "perimeter_cage", "mesh_gauge": 9}
  ],
  "restricted_zones": [
    {"zone_id": "DC1-White", "bounds": [[15,10],[21,10],[21,38],[15,38]], "policy":
["two_person_rule", "no_visitor"]}
  ],
  "egress_routes": [
    {"from": "DC1", "to": "ExitStairB", "min_clear_in": 48}
  ],
  "last_updated": "2025-08-10T16:30:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-facplan-nyc-dc1-2025-08",
    "thread_id": "uuid-blueprint-IFC-HQ-NYC-DC1-v7",
    "task_id": "uuid-derive-zones-cameras-001",
    "role": "FacilitiesSecurityAgent",
    "intent": "design",
    "policy_refs": ["NIST800-53 PE-2", "PE-3", "PE-6", "PE-10", "ISO27001 A.11",
"NFPA101"],
    "constraints": ["egress_clearance_in>=44", "max_camera_blind_spots:0",
"privacy_masking:true"],
    "decision_basis": {
      "evidence_refs": ["uri://bimserver/blueprints/IFC-HQ-NYC-DC1-v7"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/facsec/zoning-and-egress-dc"
    }
  }
}

```

```

    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/physenv/facilities-security-agent",
      "signing_kid": "kid-bim-01",
      "attestation_ref": "uri://slsa/attestations/facilities-security@sha256:bim01"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol — Physical Risk Assessments (Audit tool REST/CSV/JSON) [Informative]

Native payload

```

{
  "assessment_id": "FAC-AUD-2025-0729-DC1",
  "site": "HQ-NYC",
  "area": "DataCenter-1",
  "methodology": "CPTED+ThreatModel",
  "findings": [
    {
      "id": "R-DC1-001", "title": "No mantrap at south entrance", "likelihood": "Medium",
      "impact": "High", "control_refs": ["PE-3", "PE-10"], "recommend": "Install mantrap + anti-passback reader"},
    {
      "id": "R-DC1-002", "title": "Camera blind spot near UPS room", "likelihood": "High",
      "impact": "Medium", "control_refs": ["PE-6"], "recommend": "Add dome camera w/ 2.8mm lens"}
  ],
  "survey_date": "2025-07-29",
  "assessor": "facsec.audit.team"
}

```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-facplan-nyc-dc1-2025-08",
```

```
    "thread_id": "uuid-assess-FAC-AUD-2025-0729-DC1",
```

```
    "task_id": "uuid-plan-remediation-002",
```

```
    "role": "FacilitiesSecurityAgent",
```

```
    "intent": "design",
```

```
    "policy_refs": ["NIST800-53 PE-3", "PE-6", "PE-10", "ISO27001 A.11"],
```

```
    "constraints": ["max_camera_blind_spots:0"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": ["uri://audit/facilities/HQ-NYC/FAC-AUD-2025-0729-DC1"],
```

```
      "confidence": 0.95,
```

```
      "explanation_ref": "uri://kb/facsec/cpted-remediation"
```

```
    },
```

```
    "provenance": {
```

```
      "producer_spiffe": "spiffe://enterprise/physenv/facilities-security-agent",
```

```
      "signing_kid": "kid-audit-02",
```

```
      "attestation_ref": "uri://slsa/attestations/facilities-security@sha256:audit02"
```

```
    },
```

```
    "classification": "C2",
```

```
    "legal_hold": false
```

```
  },
```

```
  "native_payload": { ... }
```

```
}
```

Outputs (native) [Informative]

- **FacilitySecurityPlan** (REST/JSON + attachments: annotated drawings, device lists, zone matrices).
- **Events:** FacilityPlanUpdated, ConstructionWorkItem (Kafka/AMQP).
- **Tickets/Work Orders:** CMMS/PACS/VMS change items.

MCP context (required) [Informative]

mission_id; role="FacilitiesSecurityAgent"; intent="design"; provenance (SPIFFE ID, signing KID, attestation); decision_basis (evidence_refs to blueprints and risk reports).

MCP context (optional) [Informative]

policy_refs (e.g., PE-2/PE-3/PE-6/PE-10; ISO/IEC 27001 A.11; NFPA 101/75); constraints (e.g., "egress_clearance_in>=44", "two_person_rule:DC", "privacy_masking:true", "max_camera_blind_spots:0"); classification (typically C2); legal_hold.

Enforcement note [Informative]

Change gates (PEP) MUST verify provenance.attestation and **HITL sign-off** for constrained deltas (egress, barriers, CrownJewels) before CMMS/PACS/VMS apply work items.

NIST SP 800-160v2 linkage [Informative]

Develop & Implement secure designs; Maintain & Evaluate via tests/inspections and feedback.

Automation feasibility [Informative]

High for parsing, derivation, and ticket generation; HITL for code interpretations and critical-zone decisions.

Output Contracts (merged) [Informative]

OC-1: FacilitySecurityPlanPublish [Informative]

- **Producer(s):** J3
- **Topic/Path:** POST /facility/plans (plan registry)
- **Schema/Format:** FacilitySecurityPlan@1.1 (zones, paths, devices, placements, constraints_applied, diffs, attachments[])

- **Classification:** C2 (raise to C3 if sensitive vendor topology disclosed)
- **Delivery:** at-least-once
- **Ordering:** per-site
- **Idempotency-Key:** sha256(site_id, plan_version)
- **Ack/Nack:** 201 Created (plan_id); NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=30 s; exp-backoff<=5x; on failure → open ticket and halt downstream events
- **Side-Effects:** index attachments; update plan registry; emit FacilityPlanUpdated
- **HITL Token:** required when egress/barrier/CrownJewels zones change
- **Observability:** trace_id, mission_id, policy_refs, constraints_applied, evidence_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=FacilitySecurityPlan@1.1 | json_schema_uri=uri://schema/facility-security-plan-1.1.json | sha256= | producers=J3 | consumers=PlanRegistry-01, PACS-01, VMS-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: Normative.

OC-2: FacilityPlanUpdated (Event) [Informative]

- **Producer(s):** J3
- **Topic/Path:** Kafka sec.fac.plan.updated
- **Schema/Format:** FacilityPlanUpdated@1.0 (site_id, plan_id, plan_version, changeset_summary, attachments_index[])
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-site
- **Idempotency-Key:** sha256(plan_id, plan_version)
- **Ack/Nack:** broker ACK; retry on publish error

- **Side-Effects:** notify PACS/VMS to refresh topology; trigger CMMS sync
- **HITL Token:** none (informational event)
- **Observability:** trace_id, mission_id, evidence_refs
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When an integration bus (Kafka/AMQP) is present or multiple downstream consumers require fan-out

schema_id=FacilityPlanUpdated@1.0 | json_schema_uri=uri://schema/facility-plan-updated-1.0.json | sha256= | producers=J3 | consumers=PACS-01, VMS-01, CMMS-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: ConstructionWorkItem (Ticket) [Informative]

- **Producer(s):** J3
- **Topic/Path:** POST /cmms/workorders (or /pacs/changes, /vms/changes)
- **Schema/Format:** ConstructionWorkItem@1.0 (site_id, location, task_type, device_spec, materials, pre-reqs, safety, acceptance_tests)
- **Classification:** C2
- **Delivery:** exactly-once per work_item_id
- **Ordering:** per-site
- **Idempotency-Key:** sha256(plan_id, change_id)
- **Ack/Nack:** 201 Created (work_item_id) or 200 Updated; NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=15 s; exp-backoff<=5x; escalate to HITL on persistent NACK
- **Side-Effects:** link to FacilitySecurityPlan version and drawings
- **HITL Token:** required for structural barriers, egress, or CrownJewels devices
- **Observability:** trace_id, mission_id, constraints_applied, acceptance_test_refs
- **Retention/TTL:** per CMMS policy (>= 7 years preferred)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When CMMS/PACS/VMS change integration is enabled

schema_id=ConstructionWorkItem@1.0 | json_schema_uri=uri://schema/construction-work-item-1.0.json

Conformance: Normative when condition is met.

OC-4: DesignChangeImpactReport (Risk/Cost/Ops) [Informative, optional]

- **Producer(s):** J3
- **Topic/Path:** sec.fac.change_impact
- **Schema/Format:** DesignChangeImpactReport@1.0 (coverage_score_delta, blind_spot_count_delta, egress_clearance_min, cost_estimate, outage_time_estimate)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-change_request
- **Idempotency-Key:** sha256(change_request_id, plan_version)

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring is enabled for facilities design

schema_id=DesignChangeImpactReport@1.0 | json_schema_uri=uri://schema/design-change-impact-1.0.json

Conformance: Normative when condition is met.

OC-5: FeedbackIngestionEvent (Stakeholder Feedback) [Informative, optional]

- **Producer(s):** Facilities/Operations portals; J3 (aggregation)
- **Topic/Path:** sec.fac.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, artifact_id, label={helpful|neutral|harmful}, notes_url)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, artifact_id)

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_blueprints, assessing_risks, deriving_zones, computing_controls, validating_egress, generating_plan, emitting_work_items, review_HITL, contestation_workflow, failed, closed }

transition(idle -> ingesting_blueprints) when blueprint update received

transition(ingesting_blueprints -> assessing_risks) when BIM normalized

transition(assessing_risks -> deriving_zones) when risk register linked

transition(deriving_zones -> computing_controls) when zones finalized

transition(computing_controls -> validating_egress) when placements proposed

transition(validating_egress -> generating_plan) when constraints satisfied

transition(generating_plan -> emitting_work_items) when plan published

transition(* -> review_HITL) when constrained changes detected (egress/barrier/CrownJewels)

transition(* -> contestation_workflow) on stakeholder dispute

timeout(generating_plan, 30 s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(site_id, plan_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 FacilitySecurityPlanPublish	Required	Always	Authoritative secure facility plan
OC-2 FacilityPlanUpdated	Conditionally Required	Event bus present or multi-consumer fan-out needed	Synchronize downstream systems

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 ConstructionWorkItem	Conditionally Required	CMMS/PACS/VMS change integration enabled	Executable work for implementation
OC-4 DesignChangeImpactReport	Conditionally Required	Change impact scoring enabled	Risk-aware approvals and rollouts
OC-5 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement loop

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: NIST 800-53 PE-2/PE-3/PE-6/PE-10; ISO/IEC 27001 A.11; NFPA 101/75 (as referenced in constraints).
- **HITL required:** any change to egress widths/paths/door swing; structural barriers; CrownJewels zone policies; exceptions to max_camera_blind_spots:0.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; coverage_score < target for restricted zones.

SLOs and KPIs [Informative]

- PlanPublishAck_p95 <= 30 s
- WorkItemAck_p95 <= 15 s
- CoverageScore_restricted >= 0.95 (target)
- BlindSpotCount_restricted = 0 (target)
- AppealResolution_p95 <= 5 business days

Outputs index [Informative]

[OC-1 FacilitySecurityPlanPublish], [OC-2 FacilityPlanUpdated], [OC-3 ConstructionWorkItem], [OC-4 DesignChangeImpactReport], [OC-5 FeedbackIngestionEvent]

Technical Implementation Details (J3) [Informative]

Model and training profile [Informative]

model_id=facilities-design-text-model; temperature=0.1; max_tokens_out=800
prompt_pack_id=facsec-design-v1 (zoning/CPTED/egress/camera coverage heuristics)
RAG: sources={BIM index, plan registry, device catalog, risk register}; max_docs=8;
min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval gates on coverage/egress tests and hallucination bounds
guardrails: deny non-plan writes; scope writes to plan registry, event bus, CMMS/PACS/VMS change endpoints

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (blueprints, risks, deltas), ttl=365 d
semantic_memory: namespaces=["blueprints","risks","devices","plans"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced plan ledger with attachments; snapshot by site/version
consistency: at-least-once (plan publish), exactly-once (work items)
idempotency: per Output Contracts

Decision and routing logic [Informative]

coverage_score = 1 - (blind_spot_area / zone_area)
camera_density = cameras_in_zone / zone_area_sqft
egress_ok = (min_clear_in >= rule_min_clear_in) AND (door_swing in allowed_set)
risk_score = 0.5*likelihood* + 0.5*impact* (normalized to [0,1])
placement_priority = 0.5*risk_score* + 0.3*zone_criticality* + 0.2**traffic_flow_index*
route: plan → registry; events → Kafka; work items → CMMS/PACS/VMS; block or HITL
if egress_ok=false or coverage_score < threshold

Model Risk Management [Informative]

continuous_validation: daily on goldens (known floor plans) + adversarial CAD slices;
eval_pass_rate >= 99.5 percent else auto_HITL

red_team_cycle: monthly (ambiguous egress, occluded barriers, deceptive zone naming)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: what changed, why, constraints applied, evidence_refs (BIM/risk), hashes of attachments
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable order; retain diffs and chain-of-custody for attachments

Incident Response Integration [Informative]

if mission_id active (e.g., temporary barriers/lockdowns), synchronize zones and access routes; emit related work items with mission linkage

Change Impact Assessment [Informative]

emit DesignChangeImpactReport (OC-4) before promotion; thresholds gate rollout or require HITL

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-5); governance-reviewed updates to prompt_pack; never auto-train on proprietary blueprints

Data Sovereignty and Legal Hold [Informative]

classification C2 default; region-scoped storage for plan attachments; legal_hold=true overrides TTL

Interfaces (links only) [Informative]

Consumes: Blueprints (BIM/CAD via IFC/REST); Physical Risk Assessments (Audit tool REST/CSV/JSON)
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on provenance failure; sandbox plan drafts; blast-radius cap on structural change proposals; cost/QPS limits

Testing and validation [Informative]

contract tests (schema capsules); offline replay on historical plans; red-team drills; drift checks and rollback

Deployment and lifecycle [Informative]

scale on blueprint diff volume; canary plan versions; SBOM and SLSA attestations; signed outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (PE family); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27001 A.11; ISO/IEC 27002:2022; NFPA 101/75; CPTED principles; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (J3) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Blueprints (BIM/CAD via IFC/REST); Physical Risk Assessments (Audit REST/CSV/JSON)
- **Native Protocol(s) Produced:** FacilitySecurityPlan (REST/JSON + attachments); FacilityPlanUpdated & ConstructionWorkItem (Kafka/AMQP/REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="FacilitiesSecurityAgent"; intent="design"; provenance.attestation; decision_basis (evidence_refs to blueprints and risk reports)
 - **Optional:** policy_refs (PE-2/3/6/10; ISO 27001 A.11; NFPA 101/75); constraints ("egress_clearance_in>=44","two_person_rule:DC","privacy_masking:true","max_camera_blind_spots:0"); classification; legal_hold
- **Enforcement Note:** Downstream PEPs MUST require HITL token for constrained categories (egress/barriers/CrownJewels) before executing work items.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

J4. OT Monitoring Agent

Agent Blueprint [Informative]

Purpose: Monitor and protect industrial control systems (ICS/SCADA) by fusing PLC/RTU telemetry with network flow analytics to detect unsafe states, misuse, or IT→OT lateral movement; trigger **OTAlert** and, when policy allows, **OTBlockAction** (e.g., ICS firewall rule push).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **PLC/SCADA Telemetry (OPC UA / Modbus TCP):** process variables (PV, SP, CV), alarm bits (HI, HHHI), actuator states, interlock status, engineering unit ranges (euRange), quality flags.
- **OT Network Flows (IPFIX/NetFlow/Zeek):** flow tuples, service/protocol identification (modbus/dnp3/s7comm), segmentation tags (level3↔level1), connection notes, conn_state.
- **(Optional) Asset/Zone Context:** CMDB/ISA-95/IEC 62443 zone & conduit maps; device criticality; Safety Integrity Level (SIL); maintenance windows.

Model training / knowledge (what the LLM relies on):

- Prompt pack for ICS safety envelopes, common protocol misuse patterns (write-single-coil on Level 1, function code anomalies), and IT→OT segmentation violations.
- RAG sources: process limit library, alarm setpoints, piping & instrumentation diagrams (P&IDs) metadata, zone/conduit registry, approved blocklist/allowlist; do not train on raw operator PII—use evidence_refs.
- Guardrails: **no actuator writes**; enforcement limited to ICS firewall/SDN APIs; MOC token and/or **control_room_ack_required** enforced by policy; hard deny for levels marked ot_zone:level1 without pre-approved rule.

Decisions it makes (deterministic + model-assisted):

- **Unsafe state detection:** PV beyond euRange with conflicting actuator state (e.g., ReliefValve=CLOSED while Pressure>HHI); stale sensor detection.

- **Protocol misuse detection:** unsolicited writes to controllers; function codes disallowed by zone; IT→OT flows to Level 1/0.
- **Correlation:** fuse telemetry alarms with concurrent network anomalies to raise severity and confidence.
- **Block decisioning (guard-railed):** propose or execute **OTBlockAction** when policy & conditions allow (pre-approved playbooks, SIL thresholds, mission intent).
- **Classification & legal hold:** default C2; elevate to C3 if operator PII present; set legal_hold for injury/incident correlation.

Routing / where outputs go:

- **OTAlert / OTHealth** → Kafka/AMQP for SIEM/SOAR/OT dashboards.
- **OTBlockAction** → REST/gRPC to ICS firewall/SDN controllers (temporary drop/deny, time-boxed).
- **MOC work orders** → change tickets for logic hardening or permanent rule updates.

Automation scope vs. manual/HITL:

- Fully automated: telemetry/network ingest; anomaly scoring; alert emission; health reporting.
- **HITL required:** any **OTBlockAction** affecting Level 1/0 unless on pre-approved auto-block list and mission intent=contain; writes that could impact safety functions; rule persistence beyond time-boxed window.
- Manual outside agent: control logic edits; PHA/HAZOP updates; AHJ approvals after incidents.

Security Domain: Physical & Environmental Security (Industrial/OT)

Inputs (native protocols consumed) [Informative]

1. **PLC/SCADA Telemetry (OPC UA / Modbus TCP)** — process variables, alarms, actuator states.
2. **OT Network Flows (IPFIX/NetFlow/Zeek)** — protocol/use anomalies, IT↔OT segmentation breaks.

Example: Consumed Protocol — PLC/SCADA Telemetry (OPC UA) [Informative]

Native payload

```
{
  "server_uri": "opc.tcp://10.20.1.15:4840",
  "ts": "2025-08-15T13:05:21Z",
  "nodes": [
    {"nodeId": "ns=2;s=Line1.TankA.Pressure_PSI", "browseName": "Pressure_PSI",
    "value": 185.4, "euRange": {"low": 0, "high": 160}},
    {"nodeId": "ns=2;s=Line1.TankA.ReliefValve.State", "browseName": "ReliefValve",
    "value": "CLOSED"},
    {"nodeId": "ns=2;s=Line1.TankA.Alarm.HighHigh", "browseName": "Alarm_HH",
    "value": true}
  ],
  "quality": "GOOD"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-plantA-safety-incident-2025-08-15",
    "thread_id": "uuid-opcua-Line1-TankA",
    "task_id": "uuid-ot-telemetry-hh-press-001",
    "role": "OTMonitoringAgent",
    "intent": "monitor",
    "policy_refs": ["NIST800-82", "IEC62443-3-3 SR-3.2", "NIST800-53 SI-4"],
    "constraints": ["no_actuator_write_without_MOC", "safety_integrity_level>=2",
    "control_room_ack_required"],
    "decision_basis": {
      "evidence_refs": [
        "uri://opcua/10.20.1.15/nodes/Line1.TankA",

```

```

    "uri://models/ot/process-limits#tankA-psi"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/ot/pressure-relief-interlock"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ot/ot-monitoring-agent",
  "signing_kid": "kid-opcua-01",
  "attestation_ref": "uri://slsa/attestations/ot-monitor@sha256:opcua01"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — OT Network Flows (Zeek) [Informative]

Native payload

```

{
  "ts": "2025-08-15T13:05:22Z",
  "uid": "C7p5m91b3aZ6o8",
  "id.orig_h": "10.15.0.44",
  "id.orig_p": 49122,
  "id.resp_h": "10.20.1.21",
  "id.resp_p": 502,
  "proto": "tcp",
  "service": "modbus",
  "duration": 0.412,

```

```
"orig_bytes": 116,  
"resp_bytes": 64,  
"conn_state": "SF",  
"community_id": "1:L2G7VQn3W3m9n5n/8v2v1jz1CwE=",  
"note": "it_to_ot_flow",  
"tags": ["segmentation-bypass", "level3_to_level1"]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-plantA-safety-incident-2025-08-15",  
    "thread_id": "uuid-zeek-C7p5m91b3aZ6o8",  
    "task_id": "uuid-ot-netflow-alert-002",  
    "role": "OTMonitoringAgent",  
    "intent": "monitor",  
    "policy_refs": ["NIST800-82", "NIST800-53 SC-7", "IEC62443-3-3 SR-5.2"],  
    "constraints": ["ot_zone:level1"],  
    "decision_basis": {  
      "evidence_refs": [  
        "uri://zeek/logs/conn/C7p5m91b3aZ6o8",  
        "uri://cmdb/zoning/10.15.0.44->10.20.1.21:502"  
      ],  
      "confidence": 0.96,  
      "explanation_ref": "uri://kb/ot/it-ot-lateral-modbus"  
    },  
    "provenance": {
```

```

    "producer_spiffe": "spiffe://enterprise/ot/ot-monitoring-agent",
    "signing_kid": "kid-zeek-02",
    "attestation_ref": "uri://slsa/attestations/ot-monitor@sha256:zeek02"
  },
  "classification": "C2",
  "legal_hold": true
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP:** OTAlert, OTHHealth.
- **REST/gRPC:** OTBlockAction to ICS firewall/SDN controllers.
- **Change tickets:** MOC work orders for control logic hardening.

MCP context (required) [Informative]

mission_id; role="OTMonitoringAgent"; intent in {"monitor","block"}; provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

policy_refs (NIST 800-82; NIST 800-53 SI-4, SC-7; IEC 62443-3-3 SR3/SR5);
 constraints
 ("no_actuator_write_without_MOC","safety_integrity_level>=2","control_room_ack_required","ot_zone:level1"); classification; decision_basis; legal_hold.

Enforcement note [Informative]

ICS firewalls/SDN PEPs MUST verify provenance.attestation **and** require **HITL token** or pre-approved auto-block rule for Level 1/0 before honoring **OTBlockAction**; time-box rules and enforce auto-rollback unless extended with MOC token.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain resilient monitoring and guarded response in safety-critical cyber-physical systems.

Automation feasibility [Informative]

High for detection and alerting; guarded automation for blocking with explicit gates.

Output Contracts (merged) [Informative]

OC-1: OTAlert [Informative]

- **Producer(s):** J4
- **Topic/Path:** Kafka sec.ot.alert (or AMQP equivalent)
- **Schema/Format:** OTAlert@1.0 (anomaly_type, site, zone, asset_id, severity, pv/sp/cv snapshot, network_evidence_refs, telemetry_evidence_refs, policy_refs, constraints_applied, confidence)
- **Classification:** C2 (C3 if operator PII included)
- **Delivery:** at-least-once
- **Ordering:** per-asset_id
- **Idempotency-Key:** sha256(asset_id, anomaly_type, start_ts)
- **Ack/Nack:** broker ACK; retry on publish error
- **Timeouts/Retry:** first publish <= 5 s from detection
- **Side-Effects:** SIEM case open; dashboard annotation
- **HITL Token:** none (alert only)
- **Observability:** trace_id, mission_id, model_version|thresholds, evidence_refs, classification_label, provenance.attestation
- **Retention/TTL:** >= 1 year (or per plant policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=OTAlert@1.0 | json_schema_uri=uri://schema/ot-alert-1.0.json | sha256= | producers=J4 | consumers=SIEM-OT-01, SOAR-OT-01, HMI-Dash-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: OTBlockAction [Informative]

- **Producer(s):** J4

- **Topic/Path:** REST POST /icsfw/blocks or gRPC icsfw.Block/Push
- **Schema/Format:** OTBlockAction@1.0 (action_id, mission_id, rule_spec {match, action, ttl_s}, scope {conduit|level}, reason, pre_approved_ref, hitl_token?, moc_token?)
- **Classification:** C2
- **Delivery:** exactly-once per action_id (consumer enforces)
- **Ordering:** per-conduit
- **Idempotency-Key:** sha256(action_id, rule_spec_hash)
- **Ack/Nack:** ACK <= 10 s with rule_id; NACK on policy/PEP failure
- **Timeouts/Retry:** exp-backoff<=5x; auto-rollback on missing heartbeat or TTL expiry
- **Side-Effects:** append to immutable enforcement journal; notify control room/HMI
- **HITL Token:** **required** unless pre_approved_ref present and mission intent=contain at SIL >= 2
- **Observability:** trace_id, mission_id, enforcement_status, provenance.attestation
- **Retention/TTL:** 7 years (safety record)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When ICS firewall/SDN enforcement is enabled **and** policy allows blocking
 schema_id=OTBlockAction@1.0 | json_schema_uri=uri://schema/ot-block-action-1.0.json | sha256= | producers=J4 | consumers=ICSFW-01, SDN-OT-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: OTHealth [Informative]

- **Producer(s):** J4
- **Topic/Path:** Kafka sec.ot.health
- **Schema/Format:** OTHealth@1.0 (agent_status, input_lag, plc_poll_success_rate, zeek_uptime, rules_in_effect[], last_block_action)
- **Classification:** C1/C2
- **Delivery/Ordering:** at-least-once; per-site

- **Idempotency-Key:** sha256(site_id, interval_start)
- **Ack/Nack:** broker ACK
- **Retention/TTL:** 90 days

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When health/telemetry SLAs are tracked in OT SOC

schema_id=OTHealth@1.0 | json_schema_uri=uri://schema/ot-health-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: MOCWorkItem (Change Ticket) [Informative]

- **Producer(s):** J4
- **Topic/Path:** POST /cmms/moc
- **Schema/Format:** MOCWorkItem@1.0 (change_id, asset_id, rationale, risk, proposed_logic_change|permanent_rule, acceptance_tests, rollback_plan)
- **Classification:** C2
- **Delivery:** exactly-once per change_id
- **Idempotency-Key:** sha256(change_id)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** links to incidents/alerts and evidence; requires approver list

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When CMMS/MOC integration is enabled

schema_id=MOCWorkItem@1.0 | json_schema_uri=uri://schema/moc-work-item-1.0.json

Conformance: Normative when condition is met.

OC-5: IROTEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** J4
- **Topic/Path:** sec.ot.incident / REST POST /incidents/{id}/events
- **Schema/Format:** IROTEvent@1.0 (incident_id, alert_ids[], block_action_ids[], evidence_refs, decision_rationale_url)

- **Classification:** C2/C3
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, event_hash)

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When IR/SIEM integration is present or mission is active

schema_id=IROTEvent@1.0 | json_schema_uri=uri://schema/ir-ot-event-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Operator/Engineer Feedback) [Informative, optional]

- **Producer(s):** Control room/HMI portal; J4 (aggregation)
- **Topic/Path:** sec.ot.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, alert_id, label={helpful|neutral|harmful}, notes_url)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_telemetry, monitoring_network, **correlating**, alerting, proposing_block, enforcing_block, reporting_health, contestation_workflow, failed, closed }

transition(idle -> ingesting_telemetry) on OPC UA/Modbus stream connected

transition(idle -> monitoring_network) on Zeek/IPFIX feed connected

transition(ingesting_telemetry + monitoring_network -> correlating) when anomalies detected within correlation_window

transition(correlating -> alerting) when severity >= theta_alert

transition(alerting -> proposing_block) when block_candidate=true and policy allows
 transition(proposing_block -> enforcing_block) on HITL token or pre_approved_ref +
 mission intent=contain
 transition(enforcing_block -> reporting_health) when ACK received OR auto-rollback
 after ttl_s
 transition(* -> contestation_workflow) when dispute opened or safety_officer veto
 timeout(enforcing_block, 10 s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(asset_id, anomaly_type, start_ts) for alerts;
 sha256(action_id, rule_spec_hash) for blocks

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 OTAlert	Required	Always	Core OT anomaly/unsafe-state alerting
OC-2 OTBlockAction	Conditionally Required	ICS firewall/SDN enabled and policy allows blocking	Rapid containment of IT→OT abuse/unsafe
OC-3 OTHearth	Optional	OT SOC tracks health SLAs	Operations visibility
OC-4 MOCWorkItem	Conditionally Required	CMMS/MOC integration enabled	Governed hardening & permanence
OC-5 IROTEvent	Conditionally Required	IR/SIEM integration present or mission active	Incident response integration
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met

- **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- `policy_refs`: NIST 800-82; NIST 800-53 SI-4 (Monitoring), SC-7 (Boundary Protection); IEC 62443-3-3 SR 3.x/5.x.
- **HITL required:** any block at Level 1/0 unless pre-approved and mission intent=contain; rules exceeding time-box; actions altering redundancy paths.
- **Automatic HITL escalation triggers:** `model_confidence < theta_low`; `drift_detected=true`; `safety_officer_veto`; repeated alerts at same conduit; `block_failures >= 2` within 10 m.

SLOs and KPIs [Informative]

- `AlertLatency_p95 <= 5 s`
- `BlockAck_p95 <= 10 s` (when invoked)
- `FalseBlockRate_30d <= 0.1 percent`
- `MissedUnsafeEventRate_7d <= 0.5 percent` (on goldens)
- `HealthHeartbeatSLA >= 99.9 percent`
- `DriftDetect_MTTD <= 24 h`

Outputs index [Informative]

[OC-1 OTAlert], [OC-2 OTBlockAction], [OC-3 OTHealth], [OC-4 MOCWorkItem], [OC-5 IROTEvent], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (J4) [Informative]

Model and training profile [Informative]

`model_id=ot-monitor-text-model`; `temperature=0.1`; `max_tokens_out=400`

(reasoning/explanations)

`signal_models`: time-series thresholds + EWMA; rule engine for function-code allowlists; learned correlation for dual-evidence elevation

RAG: `sources={process limits, alarm setpoints, zone/conduit registry, approved blocklist}`; `max_docs=8`; `min_similarity=0.78`; citations required

`fine_tuning/adapters`: none initially; eval gates on FP/FN bounds for `unsafe_state` and `lateral_movement`

guardrails: **no actuator writes**; enforcement limited to ICS firewall/SDN; require HITL/MOC tokens as per policy

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (alerts, blocks, evidence_refs), ttl=365 d
semantic_memory: namespaces=["process","zones","conduits","blocklists","incidents"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced enforcement and alert ledger; snapshot per site/hour
consistency: at-least-once (alerts/health); exactly-once (block actions)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$unsafe_score = 0.5pressure_overage_norm + 0.3alarm_state + 0.2actuator_conflict$
 $lateral_score = 0.6segmentation_violation + 0.3protocol_disallowed + 0.1novel_src_entropy$
severity = max(unsafe_score, lateral_score) scaled to [0,1]
alert_if = severity >= theta_alert
block_candidate = (lateral_score >= theta_block) OR (unsafe_score >= theta_block and pre_approved_ref exists)
execute_block_if = block_candidate AND (HITL_token_present OR (pre_approved_ref != null AND mission_intent=contain AND SIL>=2))
routing: alerts→Kafka; blocks→ICSFW; health→Kafka; MOC tickets on recurring patterns

Model Risk Management [Informative]

continuous_validation: daily goldens/adversarial (replay/modbus_write floods);
eval_pass_rate >= 99.5 percent or auto_HITL
red_team_cycle: monthly (protocol fuzzing, replay attacks, time-shifted sensor drift)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: what/why/where/when; model_version; thresholds;
evidence_refs; block rule spec + ttl
audit_log_format: JSONL; stable field order; include enforcement ACKs and auto-rollback events
UI/API: surface classification_label, provenance.attestation, decision_rationale_url

Incident Response Integration [Informative]

emit IROTEvent (OC-5) when mission active; map severity to playbooks; include conduit/zone and evidence refs

Change Impact Assessment [Informative]

emit MOCWorkItem (OC-4) for permanent fixes; include acceptance_tests and rollback_plan

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6) from control room/operator reviews; governance-reviewed updates to rules/thresholds (no auto-training on operator PII)

Data Sovereignty and Legal Hold [Informative]

default classification C2; bind storage to plant region; legal_hold=true overrides TTL and blocks purge

Interfaces (links only) [Informative]

Consumes: PLC/SCADA Telemetry (OPC UA/Modbus TCP); OT Network Flows (IPFIX/NetFlow/Zeek); optional CMDB/zone registry
Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on provenance or PEP policy failure; auto-rollback of blocks at TTL; blast-radius caps (max N concurrent blocks per site); cost/QPS limits

Testing and validation [Informative]

contract tests for all Schema Capsules; replay harness (pcap + telemetry traces); red-team drills; drift checks and rollback

Deployment and lifecycle [Informative]

scale by stream QPS; canary block rules; SBOM + SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-82; NIST SP 800-53 (SI-4, SC-7); NIST SP 800-61 Rev. 2; NIST SP 800-137; IEC 62443-3-3; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK for ICS/D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (J4) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** PLC/SCADA Telemetry (OPC UA/Modbus TCP); OT Network Flows (IPFIX/NetFlow/Zeek)
- **Native Protocol(s) Produced:** OTAlert (Kafka/AMQP); OTBlockAction (REST/gRPC to ICSFW/SDN); OTHealth (Kafka); MOCWorkItem (REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="OTMonitoringAgent"; intent in {"monitor","block"}; provenance.attestation
 - **Optional:** policy_refs (NIST 800-82; NIST 800-53 SI-4, SC-7; IEC 62443-3-3 SR3/SR5); constraints ("no_actuator_write_without_MOC","safety_integrity_level>=2","control_room_ack_required","ot_zone:level1"); classification; decision_basis; legal_hold
- **Enforcement Note:** ICS PEPs MUST verify provenance.attestation and policy gates (HITL/MOC/pre-approved) before enforcing any block; time-box and auto-rollback MUST be supported.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

J5. Environmental Monitor Agent

Agent Blueprint [Informative]

Purpose: Monitor datacenter/environmental systems (HVAC/CRAC, UPS/PDU, fire suppression, water/leak) and generate **EnvAlert** when conditions breach thresholds; correlate conditions to racks/zones and link impacted asset IDs for rapid triage.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **HVAC/CRAC Telemetry (BACnet/IP):** temperature/humidity, airflow, device alarms, zone association, device status.
- **Power/Fire Telemetry (SNMP Traps/GETs):** UPS/PDU state, load/runtime, bypass states, suppression pre-discharge and smoke/water leak signals.
- **(Optional) CMDB/Topology:** rack↔zone mapping, asset criticality, resilience tier (N, N+1), preferred paging targets.

Model training / knowledge (what the LLM relies on):

- Prompt pack for ASHRAE TC 9.9 thermal envelopes, datacenter humidity/condensation risk, UPS runtime triage, suppression pre-discharge playbooks.
- RAG sources: thresholds catalog (ASHRAE classes), device inventory, rack↔zone map, historical incidents; do not train on PII or raw building logs—use `evidence_refs`.
- Guardrails: **auto_shutdown:false** by default; paging/incident writes scoped; egress to CMMS only via approved endpoints; region scoping (e.g., `region:us-east-1`).

Decisions it makes (deterministic + model-assisted):

- Compute zone/rack risk and raise **EnvAlert** for: OverTemp, HighHumidity, WaterLeak, Smoke, UPSOnBatteryLowRuntime, PowerLoss, CRACAlarm.
- Identify **impacted_assets[]** by joining zone/rack maps; set severity by breach magnitude, trend, redundancy (N vs N+1), and asset criticality.
- Decide **EnvRecovery** when conditions return to safe bands with stable persistence.
- Trigger incident creation/updates and on-call paging based on policy and constraints.

Routing / where outputs go:

- **EnvAlert/EnvRecovery** → Kafka/AMQP topics for SIEM/SOAR/NOC dashboards.
- **Incident/Paging** → REST to incident platform and paging API with context (assets, zone, thresholds, confidence).
- **Facilities tickets** → CMMS work orders for remediation (optional).

Automation scope vs. manual/HITL:

- Fully automated: ingest, correlation, risk scoring, alert/recovery emission, optional incident updates and paging.
- **HITL required:** any action that would shut down equipment, trigger suppression release, or change CRAC setpoints; legal_hold decisions when tied to investigations.
- Manual outside agent: physical repairs; vendor dispatch; AHJ/compliance actions.

Security Domain: Physical & Environmental Security

Inputs (native protocols consumed) [Informative]

1. **HVAC/CRAC Telemetry (BACnet/IP)** — temperatures, humidity, airflow, unit alarms.
2. **Power/Fire Telemetry (SNMP Traps/GETs)** — UPS/PDU state, battery/runtime, suppression pre-discharge.

Example: Consumed Protocol — HVAC/CRAC Telemetry (BACnet/IP) [Informative]

Native payload

```
{
  "device_instance": 3001,
  "site": "HQ-NYC",
  "zone": "DC1-RowB",
  "ts": "2025-08-15T13:20:05Z",
  "points": [
    {"object_type": "analogInput", "object_instance": 1012, "name":
"Temp_RowB_AirIn_C", "present_value": 38.4, "units": "C"},
    {"object_type": "analogInput", "object_instance": 1013, "name": "RH_RowB_Percent",
"present_value": 78.9, "units": "%"},
    {"object_type": "binaryInput", "object_instance": 2104, "name": "CRAC-02_Alarm",
"present_value": 1}
  ],
  "device_status": "online"
}
```

```
}
```

MCP-wrapped payload

```
{
```

```
"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-env-incident-nyc-dc1-2025-08-15",
  "thread_id": "uuid-bacnet-DC1-RowB-2025-08-15T13:20:05Z",
  "task_id": "uuid-eval-thermal-RowB-001",
  "role": "EnvironmentalMonitorAgent",
  "intent": "monitor",
  "policy_refs": ["NIST800-53 PE-14", "PE-11", "NFPA-75"],
  "constraints": ["notify_oncall:true", "auto_shutdown:false", "region:us-east-1"],
  "decision_basis": {
    "evidence_refs": [
      "uri://bacnet/site/HQ-NYC/device/3001/zone/DC1-RowB/2025-08-15T13:20:05Z",
      "uri://thresholds/dc/ashrae-tc9.9/class-1-allowable"
    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/env/overtemp-high-humidity-correlation"
  },
  "impacted_assets": ["srv-001", "srv-002", "srv-003", "pdu-rowB-02"],
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/physenv/environmental-monitor-agent",
    "signing_kid": "kid-bacnet-01",
    "attestation_ref": "uri://slsa/attestations/env-monitor@sha256:bacnet01"
  },
  "classification": "C2",
```

```
    "legal_hold": true
  },
  "native_payload": { ... }
}
```

Example: Consumed Protocol — Power/Fire Telemetry (SNMP) [Informative]
Native payload

```
{
  "trap_ts": "2025-08-15T13:21:12Z",
  "agent": "ups-01.dc1.example.net",
  "varbinds": {
    "1.3.6.1.2.1.33.1.2.3.0": 1,
    "1.3.6.1.2.1.33.1.2.1.0": 5,
    "1.3.6.1.2.1.33.1.2.4.0": 7,
    "1.3.6.1.2.1.33.1.4.4.1.5.1": 88,
    "1.3.6.1.4.1.318.0.46": 1
  },
  "site": "HQ-NYC",
  "zone": "DC1-RowB"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-env-incident-nyc-dc1-2025-08-15",
    "thread_id": "uuid-snmp-ups-01-2025-08-15T13:21:12Z",
    "task_id": "uuid-eval-power-RowB-002",
    "role": "EnvironmentalMonitorAgent",
  }
}
```

```

"intent": "monitor",
"policy_refs": ["NIST800-53 PE-11", "PE-13", "PE-14", "NFPA-75"],
"constraints": ["notify_oncall:true", "auto_shutdown:false"],
"decision_basis": {
  "evidence_refs": [
    "uri://snmp/traps/ups-01.dc1.example.net/2025-08-15T13:21:12Z",
    "uri://snmp/gets/ups-01.dc1.example.net/runtime-load",
    "uri://cmdb/mappings/zone/DC1-RowB->assets"
  ],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/env/ups-on-battery-runtime-risk"
},
"impacted_assets": ["srv-001", "srv-002", "srv-003", "net-core-01"],
"provenance": {
  "producer_spiffe": "spiffe://enterprise/physenv/environmental-monitor-agent",
  "signing_kid": "kid-snmp-02",
  "attestation_ref": "uri://slsa/attestations/env-monitor@sha256:snmp02"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP:** EnvAlert, EnvRecovery.
- **REST to Incident Mgmt / Paging:** create/update incident; page on-call with context.

- **Optional:** CMMS work orders for facilities remediation.

MCP context (required) [Informative]

mission_id; role="EnvironmentalMonitorAgent"; intent="monitor"; provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

policy_refs (e.g., NIST 800-53 PE-11/13/14/15; NFPA 75); constraints (auto_shutdown:false, notify_oncall:true, region:<id>); classification (typ. C2); decision_basis (evidence_refs, thresholds, confidence, explanation_ref); **impacted_assets[]**; legal_hold.

Enforcement note [Informative]

Downstream UIs/PEPs MUST honor auto_shutdown:false; any shutdown/suppression trigger requires HITL token and mission scope. Paging and incident writes must verify provenance.attestation and classification_label.

NIST SP 800-160v2 linkage [Informative]

Maintain & Evaluate: continuous sensing, impact-aware alerts, and feedback to resilience missions.

Automation feasibility [Informative]

High for ingestion, correlation, alerting, incident linkage; mechanical/electrical interventions remain HITL.

Output Contracts (merged) [Informative]

OC-1: EnvAlert [Informative]

- **Producer(s):** J5
- **Topic/Path:** Kafka sec.env.alert (or AMQP)
- **Schema/Format:** EnvAlert@1.0 (anomaly_type, site, zone, sensor_ids[], readings{}, thresholds_ref, trend, severity, impacted_assets[], policy_refs, constraints_applied, confidence, start_ts)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-zone

- **Idempotency-Key:** sha256(zone, anomaly_type, start_ts)
- **Ack/Nack:** broker ACK; retry on publish error
- **Timeouts/Retry:** first publish <= 10 s from detection
- **Side-Effects:** open/update incident if policy requires; annotate NOC dashboard
- **HITL Token:** none (alert only)
- **Observability:** trace_id, mission_id, thresholds_ref, evidence_refs, impacted_assets[], classification_label, provenance.attestation
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EnvAlert@1.0 | json_schema_uri=uri://schema/env-alert-1.0.json | sha256= | producers=J5 | consumers=SIEM-01, SOAR-01, NOC-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: EnvRecovery [Informative]

- **Producer(s):** J5
- **Topic/Path:** Kafka sec.env.recovery
- **Schema/Format:** EnvRecovery@1.0 (alert_id, site, zone, resolved_ts, readings{}, thresholds_ref, persistence_ok, residual_risk)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-zone
- **Idempotency-Key:** sha256(alert_id, resolved_ts)
- **Ack/Nack:** broker ACK
- **Side-Effects:** close/resolve incident if open and policy allows
- **Observability:** trace_id, mission_id, evidence_refs, classification_label
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When conditions return to safe bands and alert is active
schema_id=EnvRecovery@1.0 | json_schema_uri=uri://schema/env-recovery-1.0.json
Conformance: Normative when condition is met.

OC-3: IncidentNotification [Informative]

- **Producer(s):** J5
- **Topic/Path:** REST POST /incidents or POST /incidents/{id}/updates; Paging POST /oncall/page
- **Schema/Format:** IncidentNotification@1.0 (incident_id?, alert_ids[], severity, assignees[], page_targets[], decision_rationale_url)
- **Classification:** C2
- **Delivery:** exactly-once per (incident_id, update_seq)
- **Idempotency-Key:** sha256(incident_id|alert_group, update_seq|start_ts)
- **Ack/Nack:** 201/200 from incident API; paging ACK<=30 s
- **Side-Effects:** create/runbook link; route to on-call per schedule

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When incident management/paging integration is enabled or
notify_oncall:true

schema_id=IncidentNotification@1.0 | json_schema_uri=uri://schema/incident-notification-1.0.json

Conformance: Normative when condition is met.

OC-4: CMMSWorkItem (Facilities Ticket) [Informative]

- **Producer(s):** J5
- **Topic/Path:** POST /cmms/workorders
- **Schema/Format:** CMMSWorkItem@1.0 (work_item_id, zone, device, fault, steps, materials, acceptance_tests, rollback_plan)
- **Classification:** C2
- **Delivery:** exactly-once per work_item_id
- **Idempotency-Key:** sha256(work_item_id)

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When CMMS integration is enabled or policy requires facilities tickets
schema_id=CMMSWorkItem@1.0 | json_schema_uri=uri://schema/cmms-work-item-1.0.json

Conformance: Normative when condition is met.

OC-5: EnvChangeImpactReport (Threshold/Facility Impact) [Informative, optional]

- **Producer(s):** J5
- **Topic/Path:** Kafka sec.env.change_impact
- **Schema/Format:** EnvChangeImpactReport@1.0 (threshold_change, predicted_risk_delta, affected_zones[], redundancy_effect, page_policy_change)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per change request
- **Idempotency-Key:** sha256(change_req_id)

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring is enabled for environmental thresholds
schema_id=EnvChangeImpactReport@1.0 | json_schema_uri=uri://schema/env-change-impact-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback) [Informative, optional]

- **Producer(s):** NOC/Facilities portals; J5 (aggregation)
- **Topic/Path:** Kafka sec.env.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, alert_id, label={helpful|neutral|harmful}, notes_url)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per review_id

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_hvac, ingesting_power, correlating, alerting, notifying, recovering, contestation_workflow, failed, closed }

transition(idle -> ingesting_hvac) when BACnet feed active

transition(idle -> ingesting_power) when SNMP feed active

transition(ingesting_hvac or ingesting_power -> correlating) when breach detected or trap received

transition(correlating -> alerting) when severity >= theta_alert and persistence >= t_min

transition(alerting -> notifying) when policy.notify_oncall = true

transition(alerting -> recovering) when readings within thresholds for t_recover and trend improving

transition(* -> contestation_workflow) when dispute opened or false-positive claim logged

timeout(alerting, 10 s) -> failed; retry <= 5 with exp backoff

idempotency_key = sha256(zone, anomaly_type, start_ts)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 EnvAlert	Required	Always	Core environmental incident alerting
OC-2 EnvRecovery	Conditionally Required	When conditions normalize and an active alert exists	Incident lifecycle closure
OC-3 IncidentNotification	Conditionally Required	Incident mgmt/paging enabled or notify_oncall=true	Fast triage and response

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-4 CMMSWorkItem	Conditionally Required	CMMS integration enabled or policy requires facilities	Executable remediation workflow
OC-5 EnvChangeImpactReport	Conditionally Required	Change impact scoring enabled	Safe threshold and policy evolution
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: NIST 800-53 PE-11/13/14/15; NFPA 75; internal DC ops policies.
- **HITL required:** any auto_shutdown; suppression interaction; CRAC setpoint changes; actions impacting CrownJewels racks.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; drift_detected=true; stakeholder_disagreement_score >= 0.5; redundancy_breached (N only) with rising trend.

SLOs and KPIs [Informative]

- AlertLatency_p95 <= 10 s
- RecoveryEmit_p95 <= 60 s after thresholds stabilize
- FalseAlertRate_7d <= 1 percent
- MissedEventRate_7d <= 0.5 percent (on goldens)
- PageDispatch_p95 <= 30 s when notify_oncall=true

Outputs index [Informative]

[OC-1 EnvAlert], [OC-2 EnvRecovery], [OC-3 IncidentNotification], [OC-4 CMMSWorkItem], [OC-5 EnvChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (J5) [Informative]

Model and training profile [Informative]

model_id=env-monitor-text-model; temperature=0.1; max_tokens_out=400
(reason/explanations)
thresholds: ASHRAE class ranges; humidity condensation risk band; UPS runtime and load thresholds
prompt_pack_id=env-monitor-v1 (thermal/humidity/runtime taxonomy, paging rules)
RAG: sources={thresholds catalog, CMDB rack↔zone map, historical incidents};
max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval gates on FP/FN and alert timeliness
guardrails: **auto_shutdown:false** default; restrict writes to incident/paging/CMMS endpoints

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (alerts, recoveries, evidence_refs, pages), ttl=365 d
semantic_memory: namespaces=["thresholds","zones","assets","incidents"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced alert ledger; snapshot per zone/hour
consistency: at-least-once (alerts/recoveries); exactly-once (tickets/pages)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{thermal_risk} = 0.5 * (\text{temp_over_band_norm}) + 0.2 * (\text{humidity_over_band_norm}) + 0.3 * (\text{redundancy_factor})$
 $\text{power_risk} = 0.6 * (1 - \text{minutes_remaining_norm}) + 0.2 * (\text{load_ratio}) + 0.2 * (\text{bypass_active})$
severity = max(thermal_risk, power_risk) scaled to [0,1]
alert_if = (severity >= theta_alert) AND (persistence >= t_min)
recover_if = (readings within bands) AND (trend improving for t_recover)
routing: alerts→Kafka; recoveries→Kafka; incident/paging per policy; CMMS ticket if device_fault=true or repeated alerts

Model Risk Management [Informative]

continuous_validation: daily on goldens/adversarial (sensor dropout/spike);
eval_pass_rate >= 99.5 percent or auto_HITL
red_team_cycle: monthly (telemetry spoof, trap floods, inconsistent zone mapping)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: what/where/when, thresholds_ref, readings, trend,
impacted_assets; paging rationale; links to evidence_refs
audit_log_format: JSONL; stable field order; include paging ACKs and CMMS IDs
UI/API: surface classification_label, provenance.attestation, decision_rationale_url

Incident Response Integration [Informative]

emit IncidentNotification (OC-3) with alert grouping and rack impact; map severity to runbooks

Change Impact Assessment [Informative]

emit EnvChangeImpactReport (OC-5) prior to threshold/policy change; gate rollout by predicted_risk_delta

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6) from NOC reviews; governance-reviewed updates to thresholds/paging rules (no auto-train on PII)

Data Sovereignty and Legal Hold [Informative]

classification C2 default; region-scoped storage; legal_hold=true overrides TTL and blocks purge

Interfaces (links only) [Informative]

Consumes: HVAC/CRAC (BACnet/IP); Power/Fire (SNMP Traps/GETs);
CMDB/Topology
Produces: OC-1..OC-6 as enabled

Safety and abuse prevention [Informative]

kill_switch on provenance failure; rate limits on paging; blast-radius caps (max pages/minute per site); cost/QPS limits; no control writes

Testing and validation [Informative]

contract tests for Schema Capsules; replay harness with historical telemetry; red-team drills; drift checks and rollback

Deployment and lifecycle [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

scale by points/sec and trap rate; canary threshold changes; SBOM + SLSA attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 (PE-11/13/14/15); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; NFPA 75; ASHRAE TC 9.9; ISO/IEC 27002:2022; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (J5) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** HVAC/CRAC Telemetry (BACnet/IP); Power/Fire Telemetry (SNMP Traps/GETs)
- **Native Protocol(s) Produced:** EnvAlert, EnvRecovery (Kafka/AMQP); IncidentNotification (REST/Paging); CMMSWorkItem (REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="EnvironmentalMonitorAgent"; intent="monitor"; provenance.attestation
 - **Optional:** policy_refs; constraints; classification; decision_basis; impacted_assets[]; legal_hold
- **Enforcement Note:** Consumers MUST honor auto_shutdown:false; any shutdown/suppression/actuation requires HITL token.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.